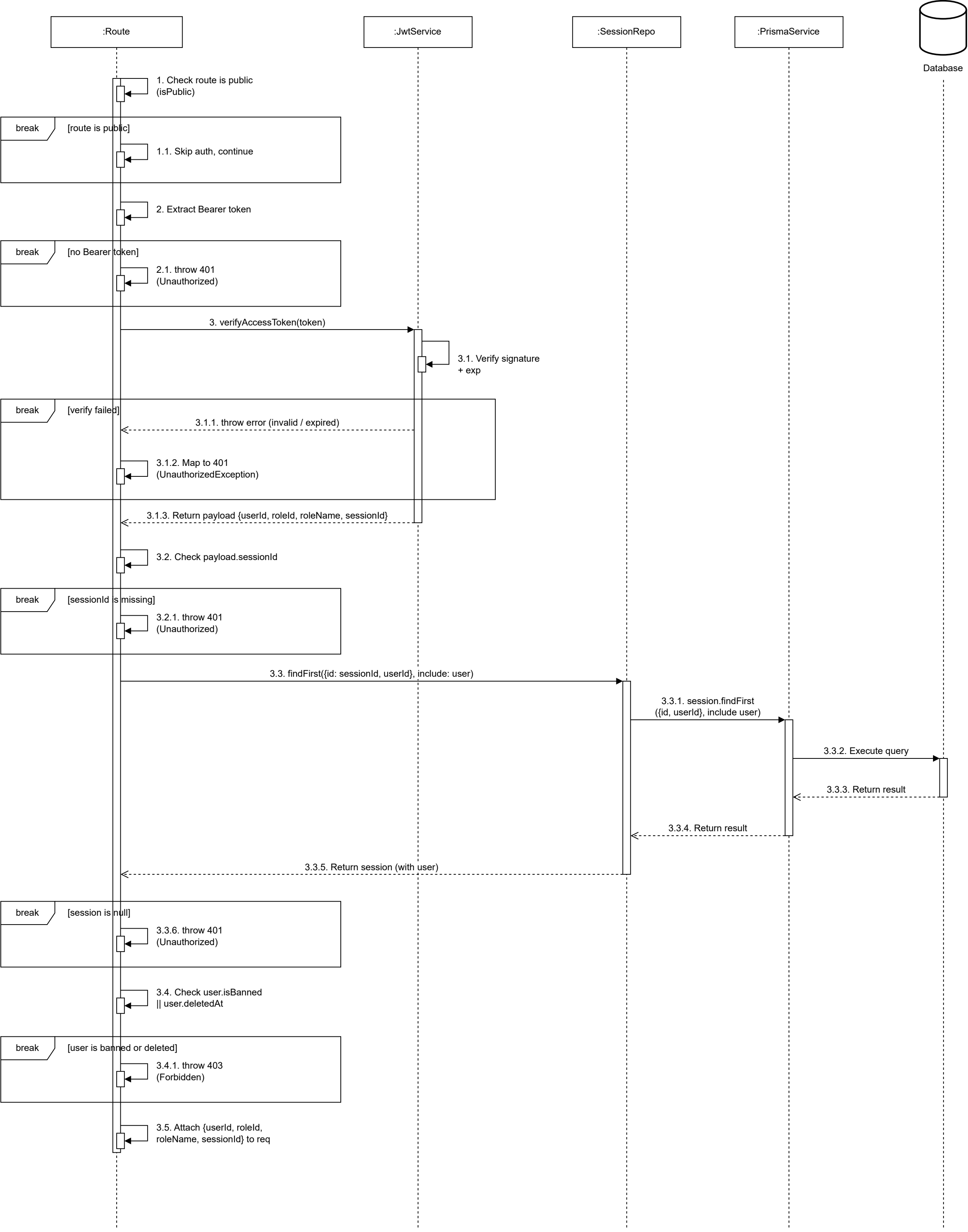
:Route
:JwtService
:SessionRepo
:PrismaService
Database
1. Check route is public (isPublic)
break
[route is public]
1.1. Skip auth, continue
2. Extract Bearer token
break
[no Bearer token]
2.1. throw 401 (Unauthorized)
3. verifyAccessToken(token)
3.1. Verify signature + exp
break
[verify failed]
3.1.1. throw error (invalid / expired)
3.1.2. Map to 401 (UnauthorizedException)
3.1.3. Return payload {userId, roleId, roleName, sessionId}
3.2. Check payload.sessionId
break
[sessionId is missing]
3.2.1. throw 401 (Unauthorized)
3.3. findFirst({id: sessionId, userId}, include: user)
3.3.1. session.findFirst ({id, userId}, include user)
3.3.2. Execute query
3.3.3. Return result
3.3.4. Return result
3.3.5. Return session (with user)
break
[session is null]
3.3.6. throw 401 (Unauthorized)
3.4. Check user.isBanned || user.deletedAt
break
[user is banned or deleted]
3.4.1. throw 403 (Forbidden)
3.5. Attach {userId, roleId, roleName, sessionId} to req